

RBAC, Privacy, Audit and Security Operations

RBAC, Privacy, Audit and Security Operations

Authorization

Use capability-based RBAC plus resource/campus scoping. Client-side hiding is convenience only; server-side checks are authoritative.

Examples:

- Hub Operator cannot release payouts.
- Incubation cannot view security evidence unless granted.
- Finance cannot silently change user roles.
- Security/admin actions require strong auditability and, where appropriate, reauthentication/dual control.

Audit model

Keep security audit events separate from product analytics.

Audit examples:

- role change,
- payout-detail change,
- refund approval,
- evidence view,
- moderation action,
- login anomaly,
- admin configuration change.

Every sensitive action should be traceable UI → API/command → database/audit row.

Data minimization

- avoid long-term student-card image retention unless necessary,
- do not expose private buyer/seller details to transfer couriers,
- separate logs from secrets,
- restrict evidence access,
- retain only what operations/legal requirements justify.